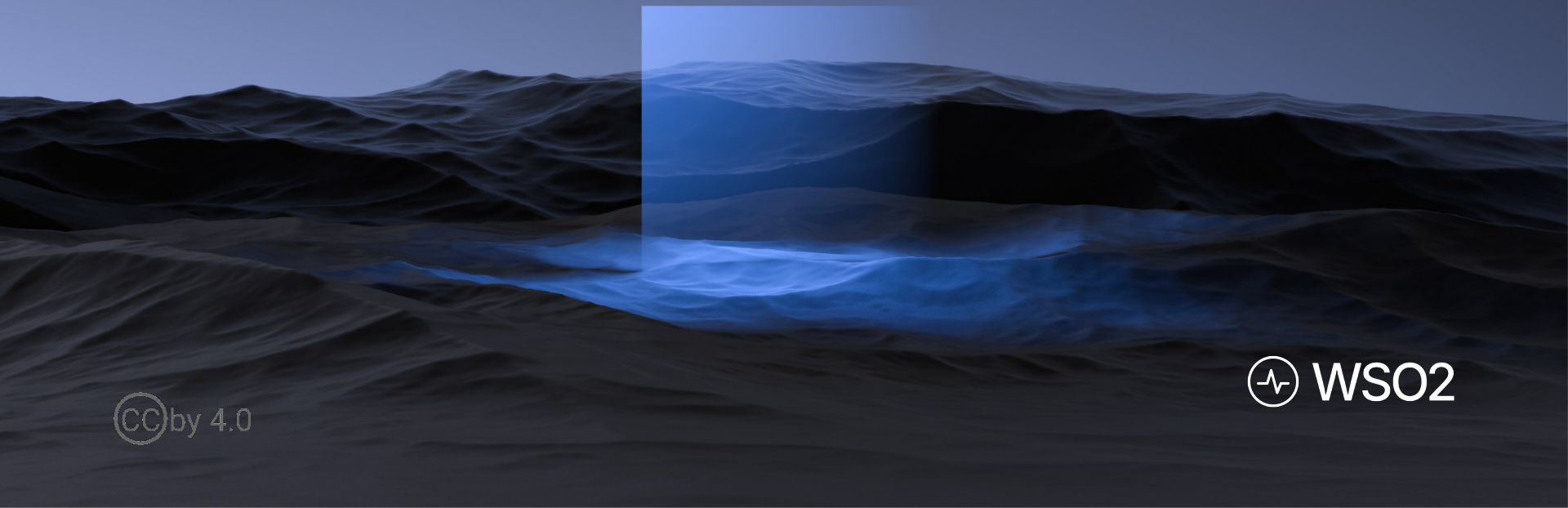
API Security



CC by 4.0

WSO2

Content

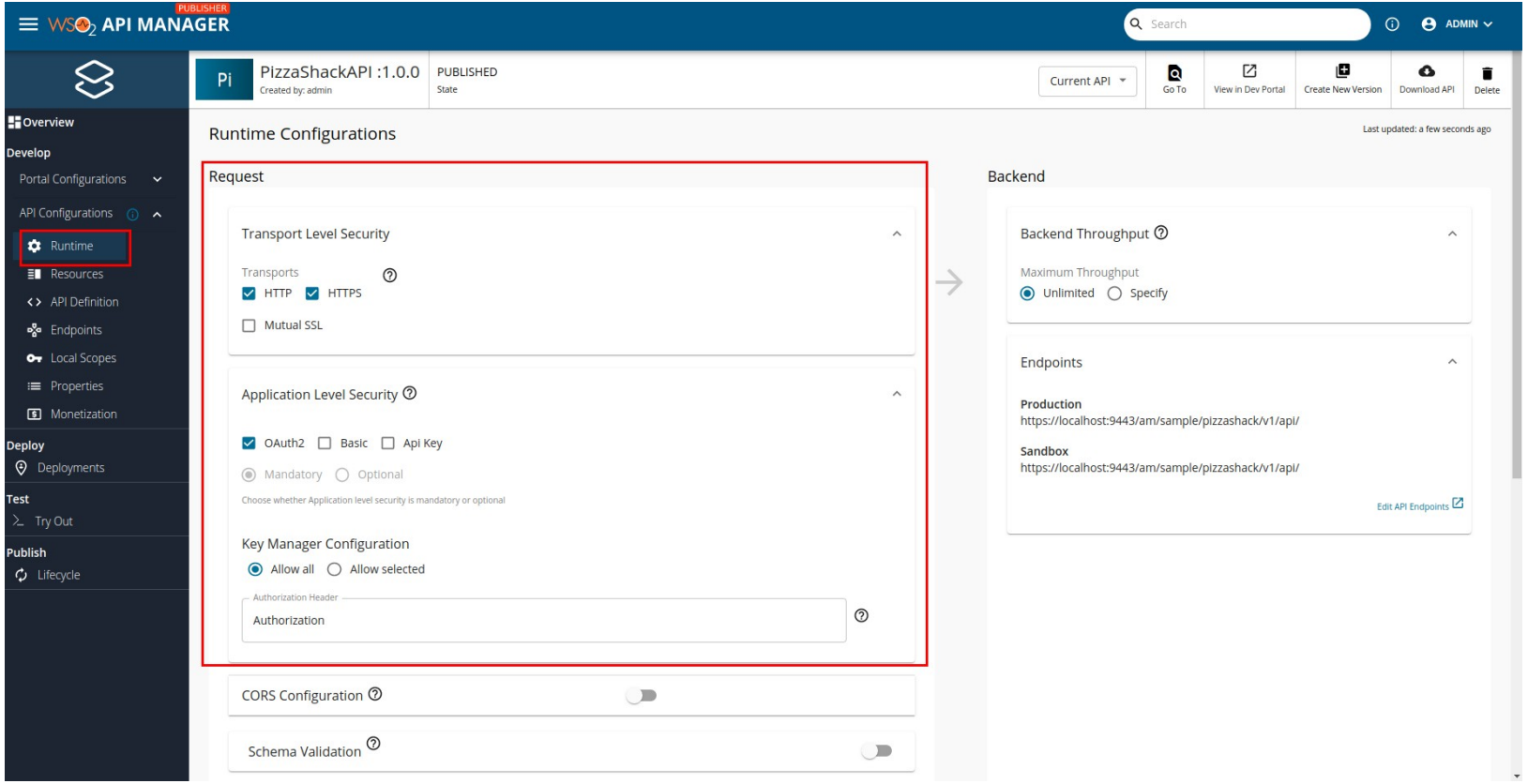
- Authentication Mechanisms
- Authorization Mechanisms
- One Time Token
- JSON Schema Validation
    - Request Validation
    - Response Validation
- Using Secured Endpoints
- Passing End User Attributes to Backend
- API Definition validation

Authentication Mechanisms

Protecting API access from unidentified or anonymous access

- OAuth2 Access Tokens
  - Direct Access Tokens
  - Exchange Access Token
- API Key
- Mutual SSL
- Basic Auth

Selecting the Authentication Mechanism for an API

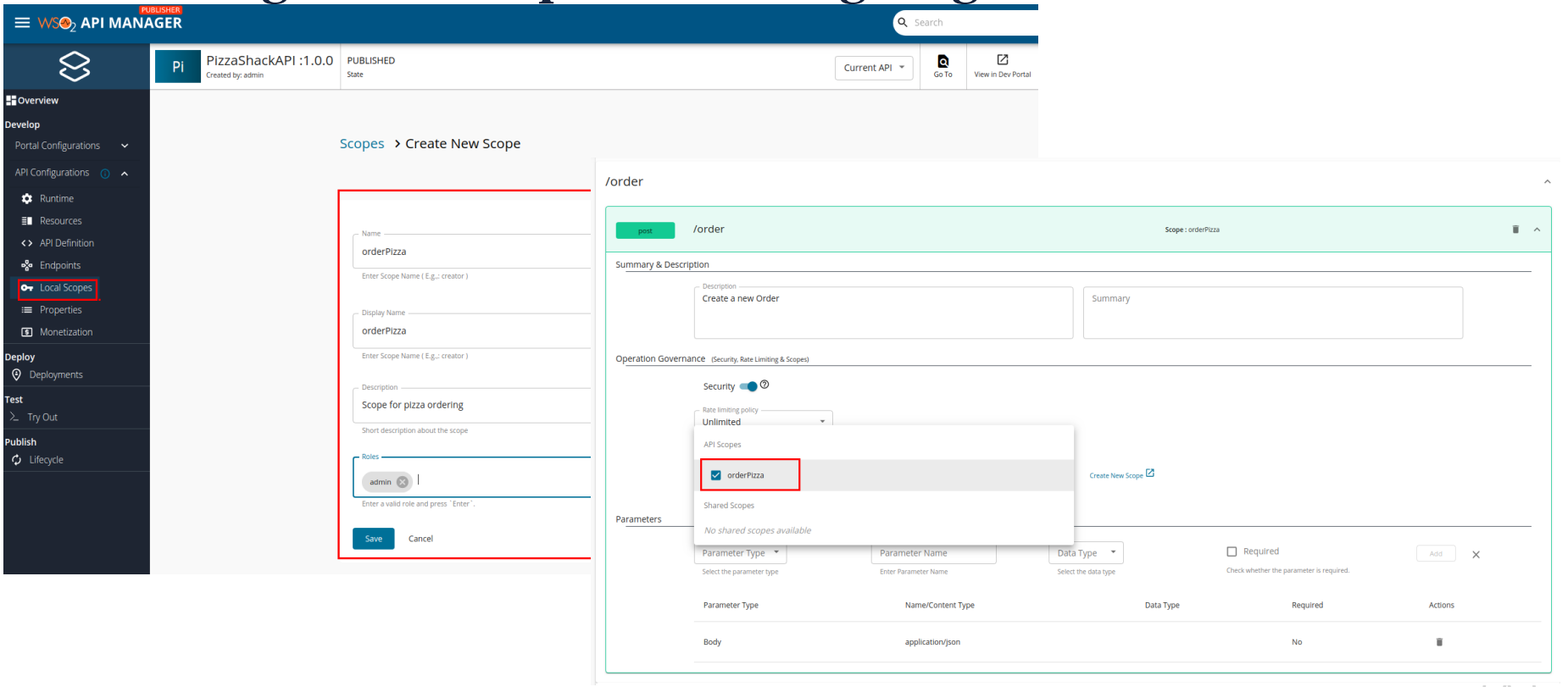


Authorization Mechanisms

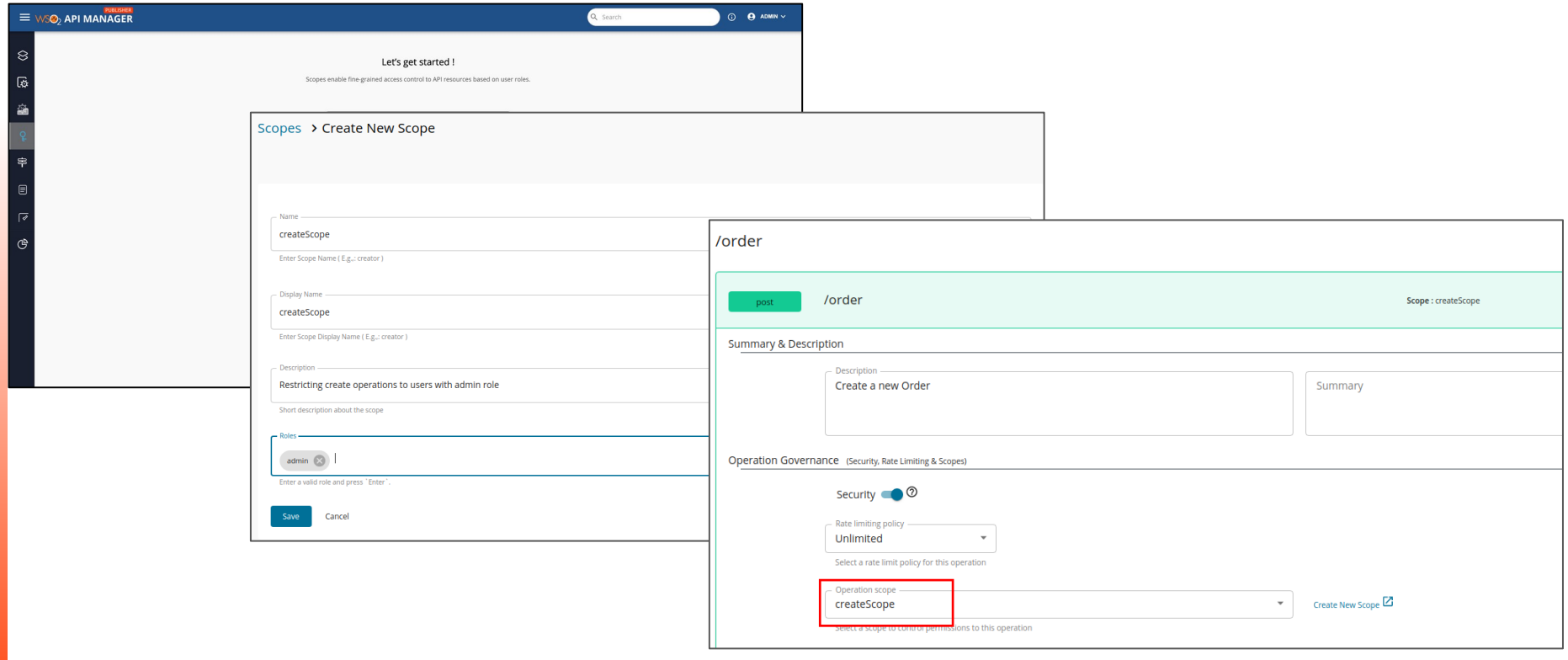
- Limit API Access
- Only Authorized parties have access to respective resources/services.
- API access control mechanisms
    - Role based access control using Scopes
    - Fine grained access control using XACML

Authorization

Creating Local Scopes and Assigning to Resources

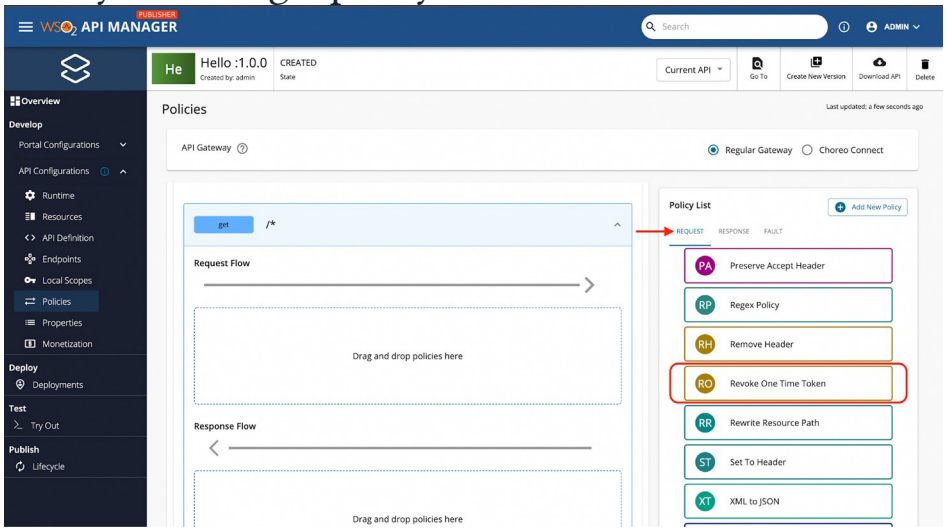


Creating Shared Scopes and Assigning to Resources



One Time Token Policy

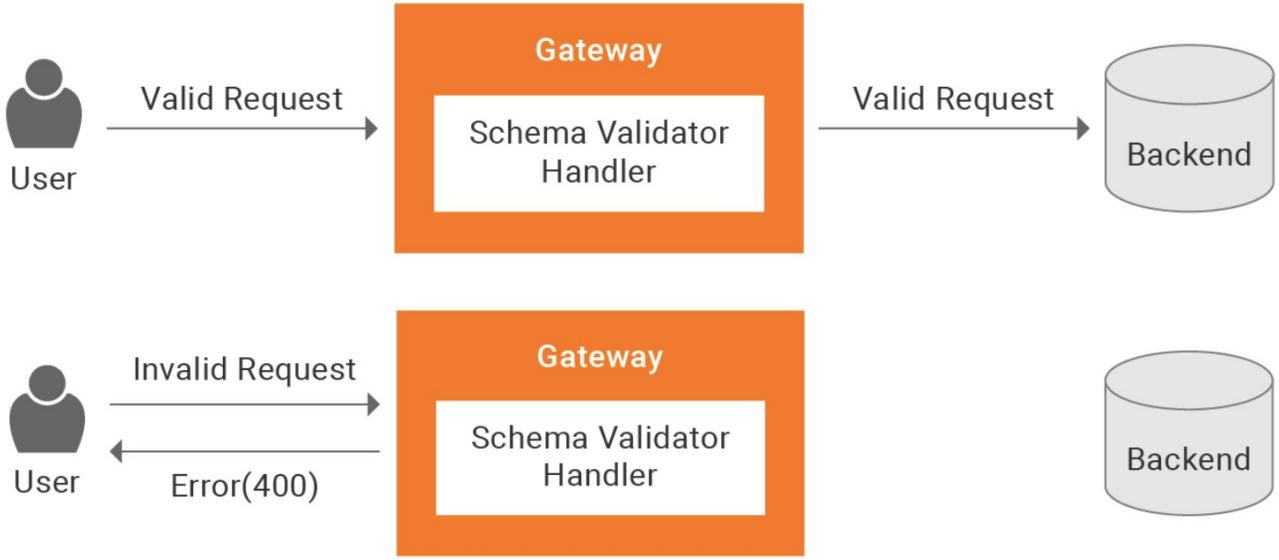
- One Time Token is a JWT that will be revoked after single usage
- Enabled by attaching a policy to the resource



Revoke One Time Tokens Policy

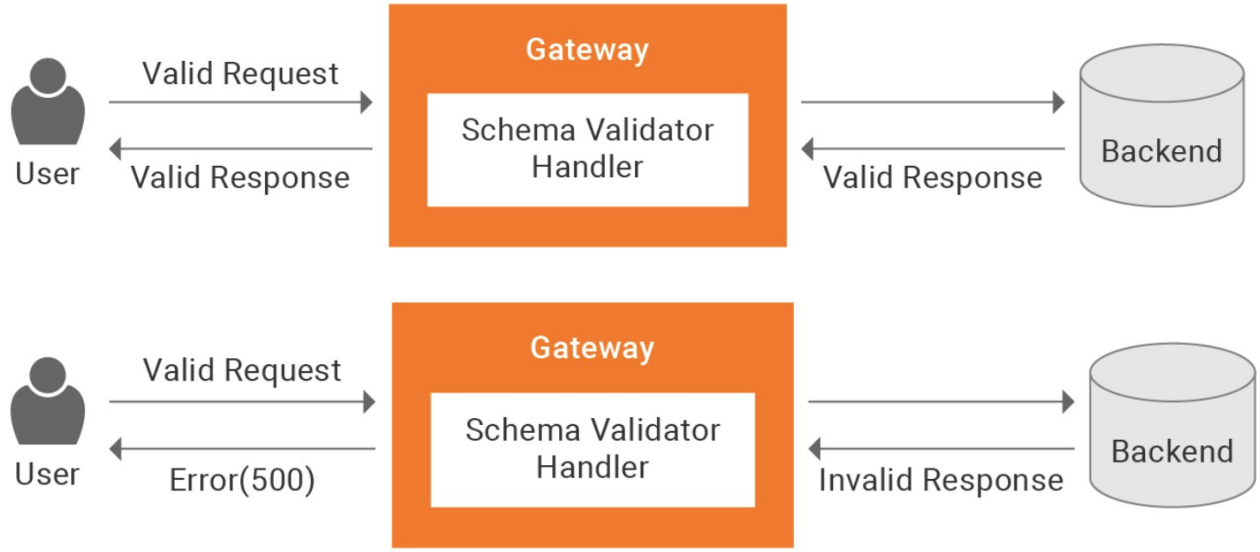
JSON Schema Validation

Request Validation



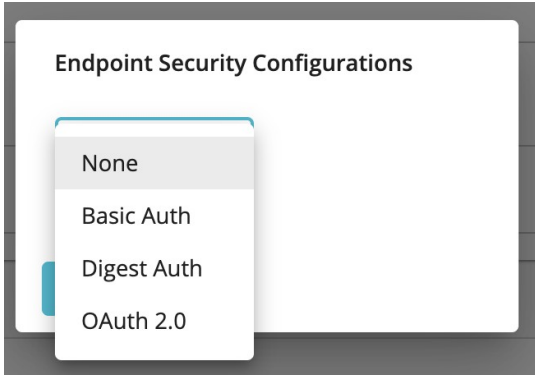
JSON Schema Validation

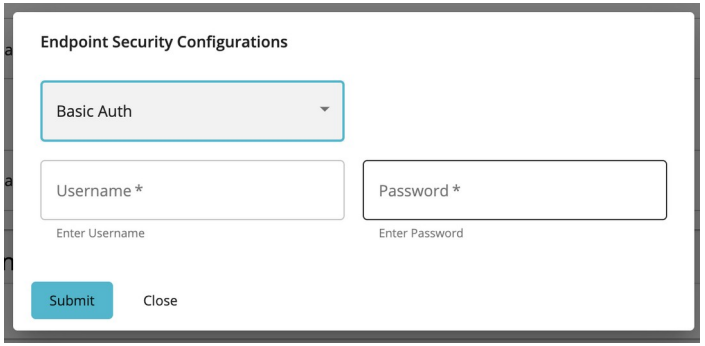
Response Validation

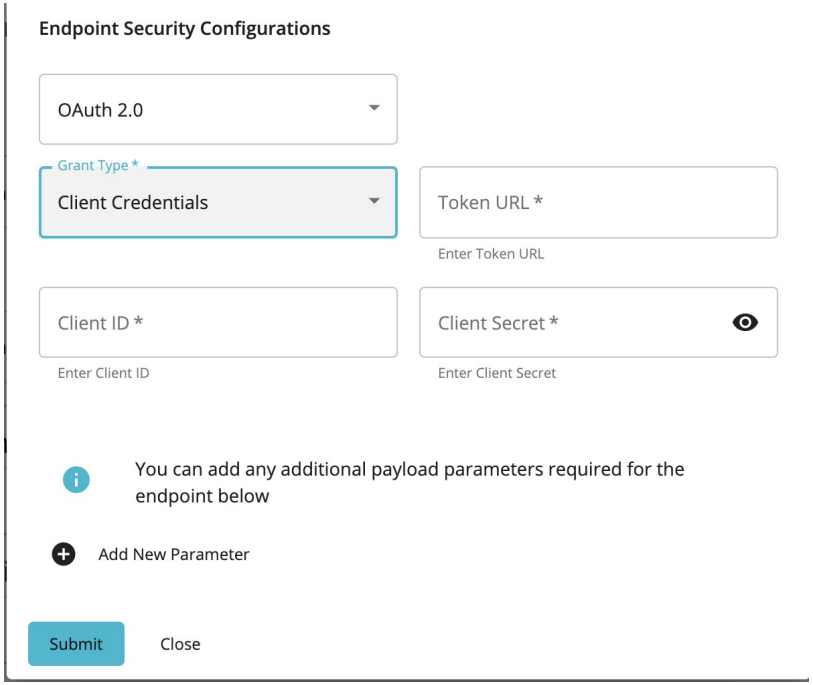


Using Secured Endpoints

- Basic Auth
- Digest Auth
- OAuth 2.0







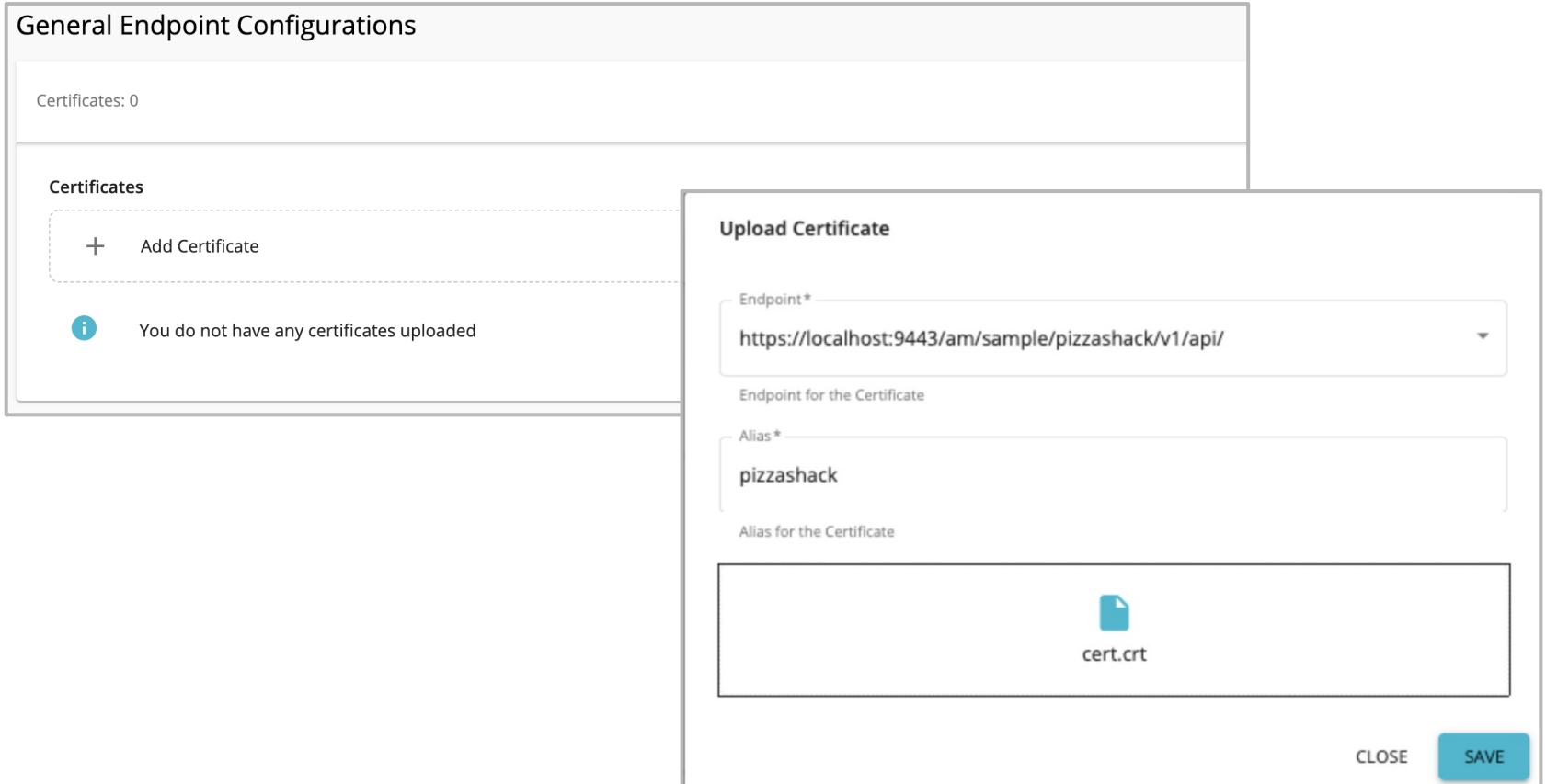
Secure Endpoints

Manage Backend Certificates

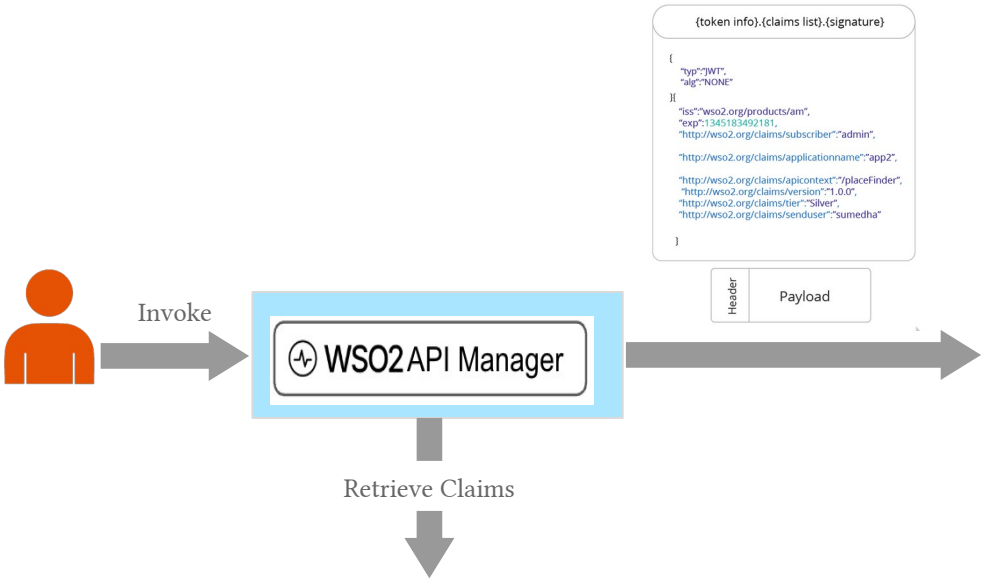
- When the API Backend is using TLS with self signed or, privately signed certificate, it's public certificate must be imported to the client-truststore.jks of the gateway.
- When doing this manually, API Manager must be restarted in order to load the new certificate.
- To avoid this, backend certificate can be uploaded in the General Configuration section in the Endpoints page.
- Once uploaded, the certificate will be loaded dynamically after some time, which can be configured in deployment.toml file.

Manage Endpoint Certificates

Upload Backend Certificates



Passing End-User Attributes to Backend.



org.wso2.carbon.apimgt.impl.token.ClaimRetriver
org.wso2.carbon.apimgt.impl.token.JWTGenerator
<apim_home>/repository/conf/deployment.toml

Passing JWT to Backend